

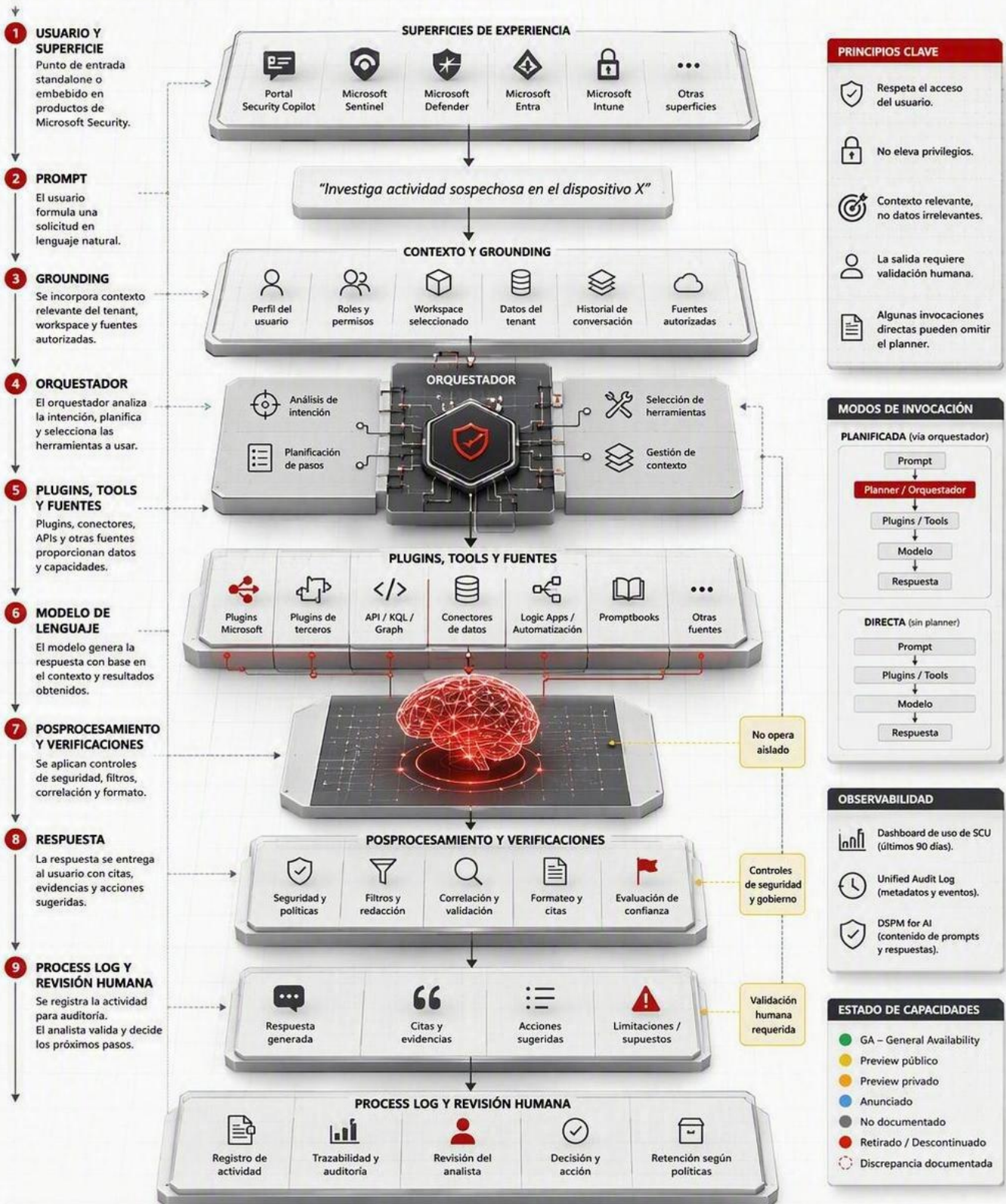
Security Copilot: del prompt a la respuesta fundamentada.

SERIE: MICROSOFT SECURITY COPILOT
ARQUITECTURA, INTEGRACIÓN,
OPERACIÓN Y GOBIERNO



1 / 12

Modelo de procesamiento de una solicitud en Microsoft Security Copilot.
La IA asiste. Las decisiones y acciones críticas requieren validación humana.



ALCANCE

Modelo lógico basado en documentación oficial de Microsoft. Los componentes y relaciones representan el procesamiento típico de una solicitud en Security Copilot.

NOTAS

- GA y Preview público consumen SCU.
- Las consultas se ejecutan on-behalf-of del usuario.
- Las experiencias embebidas usan plugins y permisos del producto de origen.

FUENTES (CLAVES)

Ver Anexo A del informe para la tabla completa de fuentes oficiales de Microsoft.
Claves: [A-xx] [B-xx] [C-xx] [D-xx] [E-xx]



Un producto, múltiples superficies

Microsoft Security Copilot está disponible en un portal standalone y embebido en múltiples productos y servicios de seguridad de Microsoft. La cobertura, capacidades y estados varían por superficie.

SERIE: MICROSOFT SECURITY COPILOT
ARQUITECTURA, INTEGRACIÓN,
OPERACIÓN Y GOBIERNO



2 / 12

EXPERIENCIA CENTRAL

• PORTAL STANDALONE



securitycopilot.microsoft.com

- Operación principal
- Administración
- Agentes y plugins
- Workspaces
- Promptbooks
- Configuración y permisos



Las experiencias embebidas dependen de:

- Plugins disponibles en la superficie
- Roles y permisos del producto de origen
- Licencias del producto de origen
- Estados de ciclo de vida de cada capacidad



MICROSOFT DEFENDER

- Resumen y análisis
- Investigación asistida
- Respuesta guiada
- Threat hunting
- Información de amenazas



MICROSOFT SENTINEL

- Triage y resumen
- Investigación e hunting
- KQL, incidentes y alertas
- Entidades y casos
- Automatización



DEFENDER FOR CLOUD

- Postura y recomendaciones
- Riesgos y cumplimiento
- Alertas y amenazas
- Configuración segura
- Resumen ejecutivo



AZURE FIREWALL

- Resumen de amenazas
- Análisis de tráfico
- Reglas y políticas
- Investigación asistida
- Recomendaciones



AZURE WAF

- Análisis de ataques
- Tráfico y reglas
- Bot protection
- Recomendaciones
- Respuesta asistida



DEFENDER THREAT INTELLIGENCE

- Intel y contexto
- Campañas y actores
- Indicadores
- Vulnerabilidades
- Análisis asistido



DEFENDER EASM

- Superficie de ataque
- Exposiciones
- Riesgos externos
- Hallazgos y monitoreo
- Recomendaciones



MICROSOFT PURVIEW

- Búsqueda y clasificación
- Resumen de alertas
- Riesgo y cumplimiento
- Actividades de insiders
- eDiscovery asistido



MICROSOFT ENTRA

- Resumen de identidades
- Riesgos y accesos
- Investigaciones
- Políticas y permisos
- Respuesta asistida



MICROSOFT INTUNE

- Resumen de dispositivos
- Cumplimiento y riesgo
- Configuraciones
- Aplicaciones y parches
- Remediación asistida

MICROSOFT SECURITY COPILOT

OTRAS SUPERFICIES Y CANALES DE ACCESO



POWER PLATFORM (CONNECTOR)

Invocar Security Copilot desde Power Automate, Power Apps y Power BI.



LOGIC APPS (SKILL / API)

Automatización y orquestación bidireccional con Security Copilot.



COPILOT STUDIO (CONNECTOR)

Crear agentes que usan Security Copilot como fuente de razonamiento.



MCP SERVERS Y COLECCIONES

Integración de herramientas externas vía Model Context Protocol.



ESCENARIOS DE DESARROLLADOR

APIs, SDKs y herramientas para construir extensiones y agentes.

PRINCIPIOS DE COBERTURA



Cobertura amplia, no homogénea.



Capacidades, roles y licencias varían por superficie.



Ocultar el panel no implica desactivar el consumo.



La integración no equivale a GA.



El contexto y los permisos provienen del producto de origen.

ESTADO DE CICLO DE VIDA

- GA – General Availability
- Preview público
- Anunciado
- No documentado
- Retirado

NOTAS CLAVE

- La disponibilidad de capacidades depende de plugins, roles, licencias y estados de cada producto.
- Algunos conectores y superficies pueden consumir SCU.
- Verificar siempre los prerrequisitos específicos de cada superficie.



LIMITACIONES GENERALES

- No disponible en nubes GCC, GCC High, DoD ni Azure Government.
- No es un servicio EU Data Boundary.
- Las capacidades en Preview público consumen SCU.
- Funcionalidades en evolución; validar antes de usar en producción.

FUENTES (CLAVES)

Ver Anexo A del informe para la tabla completa de fuentes de Microsoft.
Claves: [A-xx] [B-xx] [C-xx] [D-xx] [E-xx]



Quién puede usar qué: identidad y control de acceso

El acceso efectivo a datos y acciones depende de la combinación de roles de Security Copilot, permisos en los productos de origen, Conditional Access, plugins y workspace.

SERIE: MICROSOFT SECURITY COPILOT
ARQUITECTURA, INTEGRACIÓN,
OPERACIÓN Y GOBIERNO



3 / 12

PRINCIPIOS CLAVE

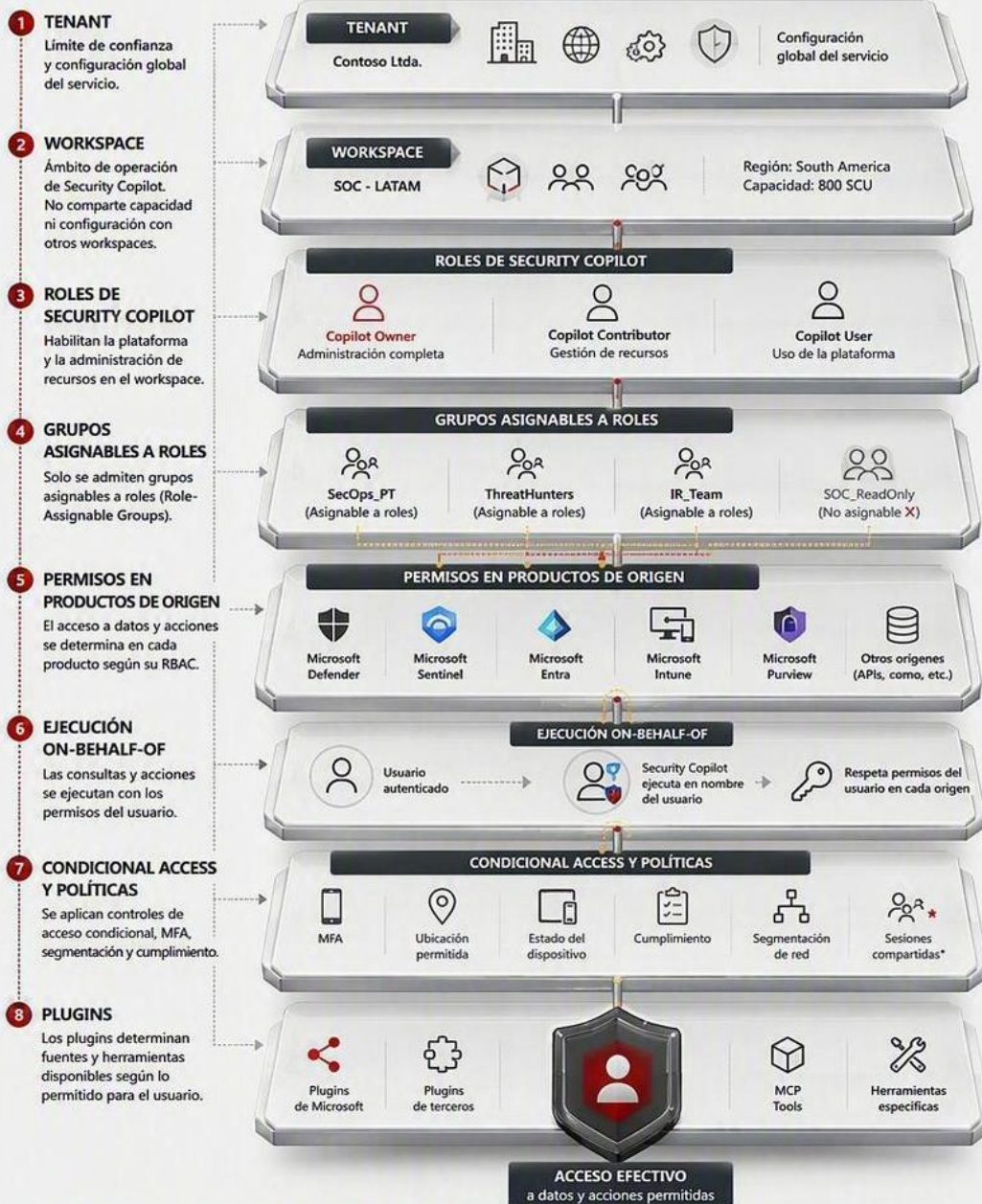
- Copilot no otorga acceso a datos por sí mismo.
- El acceso se basa en los permisos del usuario en los productos de origen.
- Solo se admiten Role-Assignable Groups.
- On-behalf-of no eleva privilegios.
- Los plugins filtran fuentes y herramientas disponibles.
- Las políticas de Conditional Access se aplican en cada invocación.

MATIZ DE RIESGO: SESIONES COMPARTIDAS

Al reanudar una sesión compartida, Security Copilot no reevalúa el acceso del plugin en el backend. Puede mostrarse información a la que el usuario ya no tiene derecho.



El acceso al plugin **NO** se revalida automáticamente. Aplicar controles de proceso y capacitación.



FLUJO DE ACCESO



MATRIZ DE CONTROL (RESPONSABILIDAD)

Microsoft Security Copilot	Plataforma, plugins, grounding, ejecución on-behalf-of.
Productos de origen	Datos, RBAC, acciones y auditoría.
Cliente / Organización	Identidades, grupos, políticas, CAP, plugins, sesiones compartidas.

ESTADO DE CICLO DE VIDA

- GA - General Availability
- Preview público
- Preview privado / LPP
- Anunciado
- Retirado / Descontinuado
- No documentado / Discrepancia

NOTAS CLAVE

- Los permisos se evalúan en cada origen.
- Copilot no almacena privilegios propios.
- Configurar y gobernar sesiones compartidas.
- El uso de plugins consume SCU (GA y Preview público).

LIMITACIONES

- No hay elevación de privilegios.
- No todas las superficies admiten todas las capacidades.
- Verifique requisitos por producto.

FUENTES (CLAVES)

Ver Anexo A del informe para la tabla completa de fuentes oficiales de Microsoft.
Claves: [A-xx] [B-xx] [C-xx] [D-xx] [E-xx]



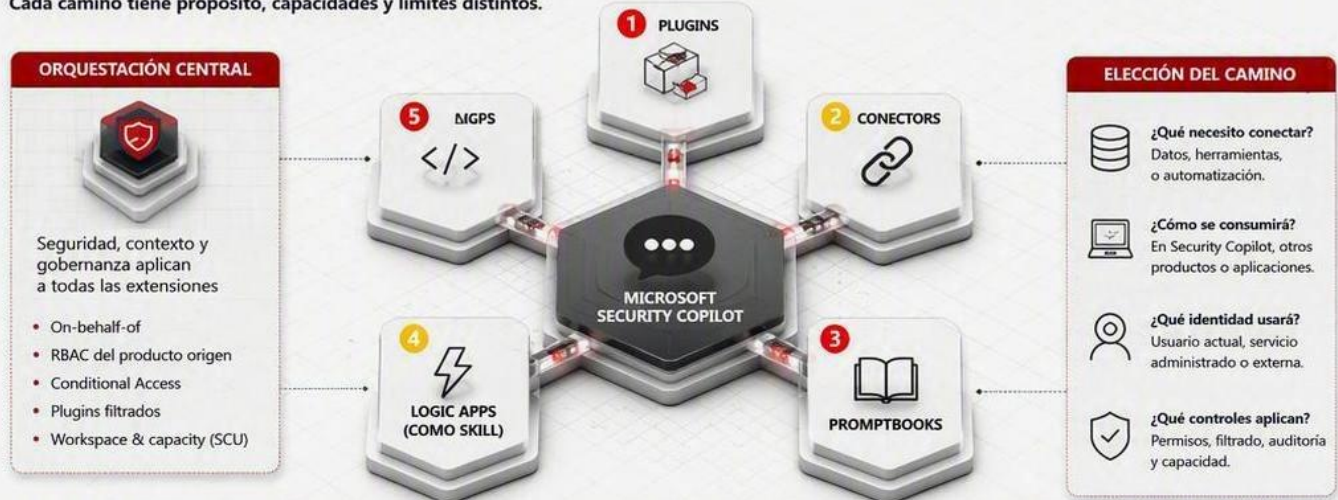
Cinco caminos para extender Security Copilot

SERIE: MICROSOFT SECURITY COPILOT
ARQUITECTURA, INTEGRACIÓN,
OPERACIÓN Y GOBIERNO



4 / 12

Security Copilot se extiende mediante mecanismos complementarios que conectan datos, herramientas y automatización al orquestador y a los agentes. Cada camino tiene propósito, capacidades y límites distintos.



COMPARACIÓN DE CAMINOS DE EXTENSIÓN

	1 PLUGINS (Microsoft, terceros y personalizados)	2 CONECTORES (Power Platform)	3 PROMPTBOOKS	4 LOGIC APPS (como Skill)	5 MCP EXTERNO
¿QUÉ APORTA?	Datos y herramientas (consumidas por el planner o por agentes).	Permite invocar Security Copilot desde aplicaciones y flujos.	Secuencias reutilizables de prompts con parámetros.	Automatización avanzada como skill con lógica, aprobaciones y acciones.	Herramientas externas expuestas via Model Context Protocol.
DIRECCIÓN DE INTERACCIÓN	Entrante: el planner/agente llama al plugin. →	Saliente: una aplicación llama a Security Copilot. ←	Entrante: se ejecuta desde Copilot por el usuario o agente. →	Entrante: el planner/agente invoca la skill. →	Entrante: el planner/agente invoca tools MCP. →
AUTENTICACIÓN	On-behalf-of (usuario actual).	Delegada o servicio administrado.	N/A (usa identidad del usuario/agente).	Servicio administrado (recomendado).	Variable (token/clave/OAuth según implementación).
ALCANCE DE USO	Solo dentro de Security Copilot.	Desde Power Platform (apps, flows, copilots).	Dentro de Security Copilot (prompt catalog).	Desde Security Copilot (agent/skill).	Desde Security Copilot, Foundry, Copilot Studio, MCP clients y más.
CAPACIDADES PRINCIPALES	• Leer datos y herramientas • Contexto y grounding • Aprobaciones y defensa • Filtro de fuentes y tools	• Automatizar consultas • Integrar en flujos • Devolver respuestas estructuradas	• Prompts parametrizables • Variables y condiciones • Reutilización y versionado • Biblioteca de prompts	• Lógica compleja • Conectores nativos • Aprobar/guardar/actuar • Respuestas estructuradas	• Tools externas • Esquemas y entradas • AllowedTools obligatorio • Discovery y catalogado
LIMITACIONES CLAVE	• Plugins API: solo lecturas • Requiere configuración en lista permitida • No ejecuta DSR	• No aporta datos al planner automáticamente • Requiere desarrollo de la app/flow	• No accede a datos por sí mismo • Depende de plugins para el contexto	• Más latencia y costo • Complejidad de diseño • Requiere buen manejo de errores	• Requiere AllowedTools • Seguridad del endpoint externo es responsabilidad del implementador
ESTADO (14-SEP-2026)	Preview público	GA	Preview público	GA	Preview público

ESCENARIOS TÍPICOS DE USO

1 PLUGINS	2 CONECTORES	3 PROMPTBOOKS	4 LOGIC APPS (SKILL)	5 MCP EXTERNO
 Enriquecer el contexto con datos de productos Microsoft, terceros o API personalizadas. Ej: obtener indicadores de amenazas de una fuente externa.	 Invocar Security Copilot desde Power Apps, Power Automate, o Copilot Studio. Ej: consulta de resumen en una aplicación interna.	 Estandarizar tareas repetitivas con prompts parametrizados. Ej: análisis de incidente con variables de fecha y scope.	 Ejecutar automatizaciones complejas con aprobaciones y acciones en sistemas corporativos. Ej: informar incidente y crear ticket.	 Usar herramientas externas estándar via MCP. Ej: consultar un motor de análisis o repositorio especializado.

LEYENDA DE ESTADO

- GA – General Availability
- Preview público
- Preview privado / LPP
- Anunciado
- No documentado
- Retirado / Descontinuado

NOTAS CLAVE

- Todos los caminos consumen SCU (GA y preview público).
- Los permisos dependen siempre del producto de origen.
- Los plugins requieren estar permitidos y filtrados.
- La sesión compartida no reevalúa el acceso al plugin.
- Verificar requisitos y dependencias antes de producción.

ADVERTENCIAS

- No todos los conectores ni plugins están en GA.
- Plugins API no permiten operaciones de escritura.
- La seguridad del endpoint externo (MCP) es crítica.
- Revisar políticas de datos, residencia y auditoría.

FUENTES (CLAVES)

Ver Anexo A del informe para la tabla completa de fuentes de Microsoft.

Claves: [A-xx] [B-xx] [C-xx] [D-xx] [E-xx]



Agentes de seguridad:

Microsoft, partners, propios o Foundry

SERIE: MICROSOFT SECURITY COPILOT
ARQUITECTURA, INTEGRACIÓN,
OPERACIÓN Y GOBIERNO



5 / 12

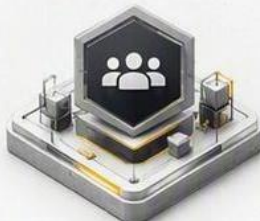
Security Copilot funciona con distintos tipos de agentes.
La elección impacta la identidad, las herramientas disponibles,
el ciclo de vida, el gobierno y el costo.

TIPOS DE AGENTES

1 AGENTES DE MICROSOFT



2 AGENTES DE PARTNERS



3 AGENTES PROPIOS (SECURITY COPILOT)



4 AGENTES DE FOUNDRY



	IDENTIDAD	Microsoft (propietaria del agente)	Partner (proveedor del agente)	Usuario/Workspace existente del tenant	Identidad dedicada en Microsoft Foundry
	TRIGGER	Manual, por eventos o programado	Manual, por eventos o programado	Manual o programado	Manual, por eventos o programado
	HERRAMIENTAS	Conectores nativos y capacidades de Microsoft Security	Herramientas del partner + conectores nativos de Microsoft	Plugins, conexiones y herramientas definidas por el usuario	Runtime, herramientas y conectores de Microsoft Foundry
	PUBLICACIÓN	Disponible en Security Copilot	Disponible en Security Store	Usuario o workspace (no publicable en Security Store)	Catálogo de modelos y agentes de Microsoft Foundry
	OBSERVABILIDAD	Trazas en Security Copilot (activity explorer, logs)	Trazas en Security Copilot y telemetría del partner	Trazas en Security Copilot y logs del workspace	Trazas en Foundry + exportables
	COSTO	Consume SCU (incluido con E5/E7 según elegibilidad)	Suscripción del partner + consume SCU	Consume SCU	Consume SCU + costos de Foundry (según uso)
	ESTADO (14-SEP-2026)	Mayoría en Preview público	Mayoría en Preview público	Preview público	Preview público
	GOBIERNO Y CONTROL	Gobernado por Microsoft según políticas del servicio	Gobernado por el partner + políticas del servicio	Gobernado por el tenant y el workspace	Gobernado por el tenant y Microsoft Foundry
	DEPENDENCIA DE TERCEROS	No depende de terceros externos	Depende del partner (SLA, disponibilidad)	No depende de terceros	Depende de los servicios de Microsoft Foundry
	MEJOR ENCAJE	Casos estándar con cobertura nativa y actualizada por Microsoft	Casos especializados del ecosistema y herramientas del partner	Casos internos específicos o necesidades locales del tenant	Casos propios que requieren IA avanzada, modelos y orquestación compleja

RELACIÓN CON SECURITY COPILOT



FACTORES DE ELECCIÓN

- ✓ Cobertura funcional requerida
- ✓ Herramientas y conectores necesarios
- ✓ Nivel de personalización
- ✓ Modelo de identidad y gobierno
- ✓ Costos y consumo de SCU
- ✓ Dependencia del ecosistema

CONSIDERACIONES CLAVE

- Toda invocación consume SCU (GA y Preview público).
- Los permisos del usuario se aplican a los datos y acciones.
- Los agentes operan con las herramientas y límites definidos.
- La validación humana sigue siendo obligatoria.

LIMITACIONES

- Muchos agentes y capacidades se encuentran en Preview.
- Las herramientas disponibles varían por tipo de agente.
- No todos los escenarios requieren agentes.
- La publicación en Security Store es exclusiva para partners.

FUENTES (CLAVES)

Ver Anexo A del informe para la tabla completa de fuentes de Microsoft.

Claves: [A-xx] [B-xx] [C-xx] [D-xx] [E-xx]



SCU: cómo se consume, factura y limita Security Copilot

SERIE: MICROSOFT SECURITY COPILOT
ARQUITECTURA, INTEGRACIÓN,
OPERACIÓN Y GOBIERNO



6 / 12

Security Copilot utiliza Security Compute Units (SCU) para ejecutar capacidades.
El consumo es compartido en el tenant, controlado por capacidad (capacity)
y workspaces, no por usuario.

1 CARGAS QUE CONSUMEN SCU



2 MODELO DE CONSUMO



3 CAPACIDAD INCLUIDA

INCLUIDA CON MICROSOFT 365
E5 Y E7 (desde 18-nov-2025)

1000
LICENCIAS
DE USUARIO
DE PAGO → 400
SCU / MES

HASTA UN TOPE DE
10.000
SCU / MES

- Sin coste adicional.
- No acumulable entre meses.
- Sujeto a elegibilidad y términos.

4 PRECIOS (FUERA DE E5 / E7)

PROVISIONED
(por hora)
4 USD
por SCU
facturado por hora
Renovable cada
hora de reloj.

OVERAGE
(por hora)
6 USD
por SCU
de overage
Facturado por hora
cuando se supera
la capacidad.

Precios en USD. Pueden variar por región.
Consulte la página oficial de precios.

5 VISIBILIDAD Y CONTROL



6 AGOTAMIENTO Y CONTROLES

¿QUÉ SUCEDE SI SE AGOTA LA CAPACITY?



- Las invocaciones pueden ser bloqueadas hasta la siguiente renovación horaria.
- Las cargas en ejecución pueden completarse según la disponibilidad.

CONTROLES COMPENSATORIOS

- 🔔 Configurar alertas de umbral.
- 🔍 Revisar y optimizar prompts y agentes.
- 🎯 Priorizar capacidades GA cuando sea posible.
- 👤 Supervisar por workspace y por carga.
- 🔒 Definir ventanas de uso intensivo.



REGLA CLAVE
GA y Preview público consumen SCU.
Solo Preview privado está exento.

7 WORKSPACES



8 BUENAS PRÁCTICAS

- 📏 Medir antes de escalar.
- 🎯 Asignar capacity por propósito de negocio.
- 📅 Revisar capacidades incluidas por licenciamiento.
- 🔍 Controlar overage según apetito de riesgo/costo.
- 📁 Documentar dependencias y cargas críticas.

RESUMEN RÁPIDO



El consumo es
compartido y
por hora.



Lo no consumido
expira cada
hora.



No hay cuotas
por usuario
o grupo.



GA y Preview
público consumen
SCU.



Los workspaces
no comparten
capacity.



Use el dashboard
para decidir y
optimizar.

ESTADO DE CICLO DE VIDA

- GA - General Availability
- Preview público
- Preview privado / LPP
- Anunciado
- No documentado
- Retirado / Descontinuado

NOTAS CLAVE

- La capacity se renueva por hora de reloj.
- Las SCU no se comparten entre workspaces.
- Preview privado no consume SCU.
- El overage puede generar costos imprevistos.
- Verifique elegibilidad de capacidad incluida.



LIMITACIONES

- No disponible en nubes GCC, GCC High, DoD ni Azure Government.
- No es un servicio EU Data Boundary.
- La disponibilidad de capacidades depende del estado (GA / Preview).

FUENTES (CLAVES)

Ver Anexo A del informe para la tabla completa de fuentes de Microsoft.

Claves: [A-xx] [B-xx] [C-xx] [D-xx] [E-xx]



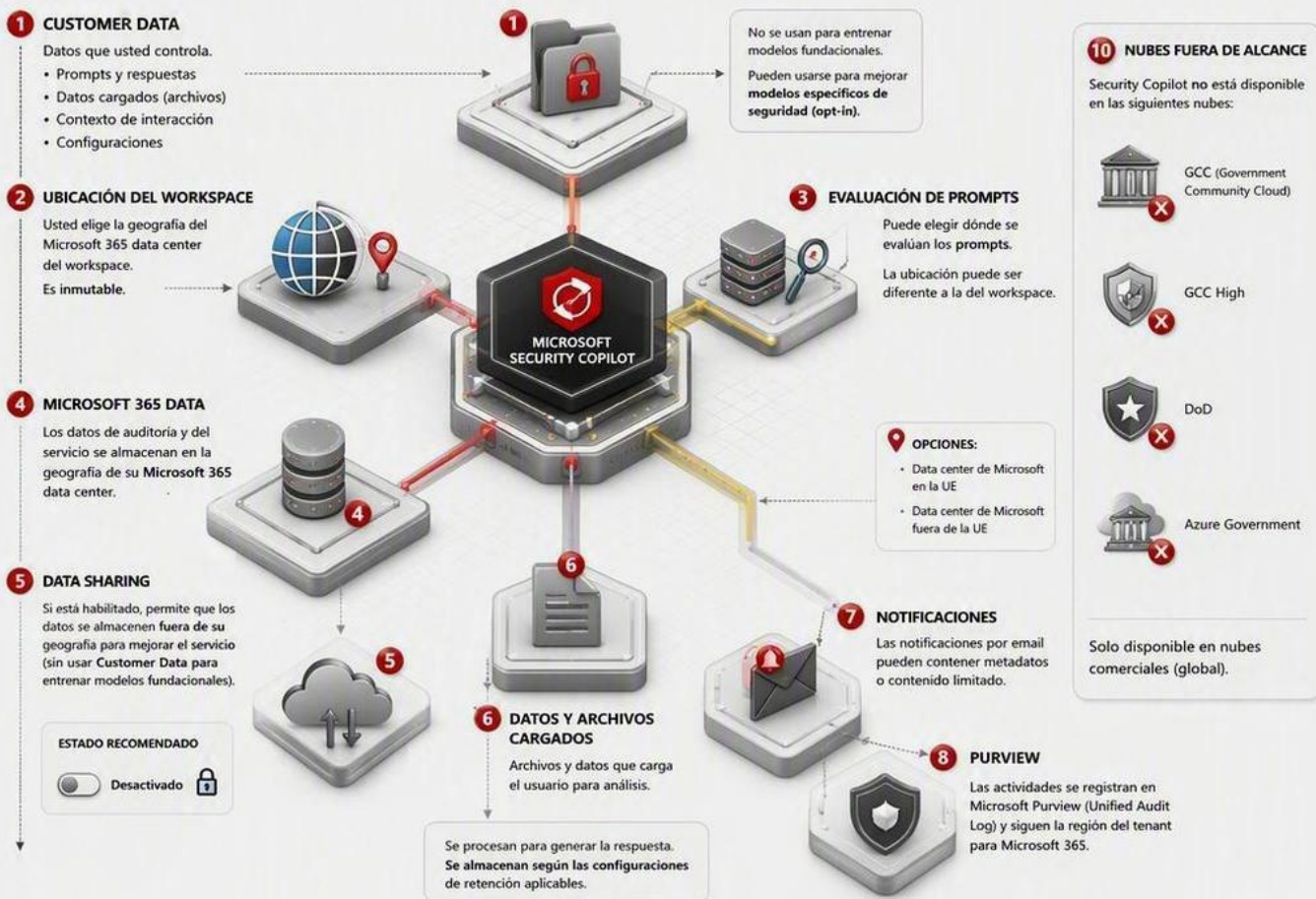
Dónde viajan y permanecen los datos

SERIE: MICROSOFT SECURITY COPILOT
ARQUITECTURA, INTEGRACIÓN,
OPERACIÓN Y GOBIERNO



7 / 12

Security Copilot procesa distintos tipos de datos. La residencia y el uso dependen de la configuración del tenant, del workspace y de las opciones de privacidad. El cumplimiento es por configuración, no por diseño del servicio.



9 RETENCIONES

Las retenciones aplicadas en Microsoft 365, Purview o en la solución de origen se aplican también a los datos procesados por Security Copilot.



RETENCIÓN POR DEFECTO (EJEMPLOS)

Tipo de dato	Retención por defecto
Customer Data (prompts y respuestas)	No se retiene por defecto
Unified Audit Log (Purview)	180 días
Security Copilot Data (logs de servicio)	180 días
Chat sessions	28 días



VARIABLE POR CONFIGURACIÓN

Puede extenderse mediante políticas de retención corporativas aplicables.

FLUJOS DE DATOS PRINCIPALES

Flujo principal (dentro de la geografía seleccionada)

Flujo opcional (según configuración)

Puede salir de la geografía (si está habilitado)

DE PRODUCTOS DE ORIGEN

Datos operativos, telemetría, alertas e información de contexto.



MICROSOFT SECURITY COPILOT

Procesamiento con grounding, plugins, modelos y controles.



RESPUESTA AL USUARIO

Resumen, análisis, recomendaciones y acciones asistidas (según permisos).

REGISTROS Y AUDITORÍA

Se registra la actividad según las políticas del tenant y productos.



PRINCIPIOS DE PRIVACIDAD

- ✓ Usted controla sus datos.
- ✓ Acceso basado en permisos.
- ✓ Sin uso de Customer Data para entrenar modelos fundacionales.
- ✓ Opt-in para mejoras de modelos específicos de seguridad.

CONSIDERACIONES CLAVE

- Definir geografía del workspace y evaluación.
- Desactivar Data Sharing si no es necesario.
- Revisar políticas de retención aplicables.
- Auditoría habilitada en Purview.
- Validar cumplimiento normativo por configuración.



LIMITACIONES

- No es un servicio EU Data Boundary.
- Los datos pueden salir de la geografía si Data Sharing está habilitado.
- Las retenciones por defecto pueden ser menores a las requeridas.

FUENTES (CLAVES)

Ver Anexo A del informe para la tabla completa de fuentes de Microsoft.

Claves: [A-xx] [B-xx] [C-xx] [D-xx] [E-xx]



Del incidente a la respuesta asistida

SERIE: MICROSOFT SECURITY COPILOT
ARQUITECTURA, INTEGRACIÓN,
OPERACIÓN Y GOBIERNO



8 / 12

Security Copilot asiste en cada etapa del ciclo de respuesta.
La IA propone, el analista decide y ejecuta con las herramientas del entorno.

ETAPA	ANALISTA / SOC	SECURITY COPILOT	HERRAMIENTAS Y FUENTES	AGENTES / AUTOMATIZACIÓN	RESULTADO / SALIDA
1 ALERTA E INCIDENTE La alerta se ingresa en Defender o Sentinel y se crea el incidente.	Revisa la alerta y abre incidente.	Ingesta contexto: alerta, entidad, máquina, usuario, IP, etc.	Microsoft Defender XDR Microsoft Sentinel Otras fuentes (logs, TI)	—	Incidente creado con contexto inicial centralizado.
2 RESUMEN INICIAL Copilot genera un resumen ejecutivo del incidente y el contexto relevante.	Solicita resumen del incidente.	Genera resumen: cronología, entidades, impacto, evidencias.	Alertas, logs, TI Graph de seguridad Vulnerabilidades	—	Resumen ejecutivo con puntos clave y evidencias.
3 TRIAGE Y CLASIFICACIÓN Prioriza, clasifica y recomienda próximos pasos e hipótesis.	Valida clasificación y prioridad.	Sugiere severidad, hipótesis y acciones inmediatas.	Modelos de IA Detecciones Playbooks	—	Triage completado con plan sugerido.
4 INVESTIGACIÓN GUIADA Guía el análisis con preguntas, evidencias y correlaciones.	Sigue la guía y ejecuta las acciones sugeridas.	Propone preguntas, correlaciones y rutas de investigación.	Defender XDR Sentinel Inteligencia de amenazas	Playbooks Logic Apps	Investigación estructurada y evidencias reunidas.
5 HUNTING Y KQL Ejecuta consultas KQL, analiza resultados y descubre actividades.	Ejecuta y revisa consultas KQL.	Genera y explica KQL, interpreta resultados, identifica patrones.	Microsoft Sentinel Data lake KQL Databases	—	Hallazgos de caza documentados (KQL, gráficos).
6 ANÁLISIS DE ARTEFACTOS Analiza scripts, archivos, URL, entidades y reportes de dispositivos.	Sube artefactos para análisis.	Analiza scripts, archivos, URL, dispositivos y reportes.	Análisis de archivos Sandboxes Threat Intelligence	—	Análisis técnico con indicadores y veredicto recomendado.
7 AUTOMATIZACIÓN Y AGENTES Orquesta tareas, playbooks y agentes para acelerar la respuesta.	Revisa tareas automatizadas.	Orquesta agentes, playbooks y tareas de forma asistida.	Logic Apps Power Automate Model Context Protocol (MCP)	Agentes de Microsoft Agentes propios Agentes de partners	Tareas ejecutadas con trazabilidad.
8 ACCIONES DE RESPUESTA Ejecuta o recomienda acciones de contención, corrección y recuperación.	Confirma o ejecuta acciones sugeridas.	Recomienda contención, corrección y recuperación.	Defender XDR Intune Entra Firewall / Cloud	Playbooks Live response Automatic disruption*	Acciones aplicadas y estado del incidente actualizado.
9 INFORME Y ACTIVIDAD POSTERIOR Resume hallazgos, genera informes y acciones de seguimiento.	Valida informe y define siguientes pasos.	Genera informe del incidente y acciones de seguimiento.	Histórico del incidente Logs y auditoría Fuentes consultadas	—	Informe final y plan de seguimiento documentado.

CAPACIDADES CLAVE DE SECURITY COPILOT EN EL CICLO



Comprensión del incidente
Resume, correlaciona y contextualiza.



Búsqueda y análisis
Hunting, KQL, gráficos y exploración guiada.



Automatización asistida
Orquesta playbooks, Logic Apps y agentes.



Análisis técnico profundo
Scripts, archivos, dispositivos, URL y entidades.



Documentación e informe
Síntesis, reporte y lecciones aprendidas.

CONSIDERACIONES IMPORTANTES

- La IA asiste, el analista decide.
- Algunas acciones requieren permisos elevados en los productos de origen.
- Hunting opera en modo de solo lectura.
- Las acciones automáticas son reversibles según la documentación.
- El incident report no captura todas las acciones de live response o API.

REQUISITOS

- Licencias de Security Copilot (SCU).
- Permisos en productos de origen.
- Conectores y fuentes integradas.
- Auditoría y retención habilitadas.
- Workspace y capacidad disponibles.

NOTAS DE CAPACIDAD (SCU)

- GA y Preview público consumen SCU.
- Preview privado no consume SCU.
- El consumo se comparte por workspace.
- La capacidad no se comparte entre workspaces ni entre meses.
- El **overage** puede generar costo adicional.

FUENTES (CLAVES)

Ver Anexo A del informe para la tabla completa de fuentes de Microsoft.

Claves: [A-x0] [B-xx] [C-xx] [D-xx] [E-xx]



LEYENDA

Flujo principal

Asistencia / Sugerencia

Flujo de integración

Acción del analista

Automatización / Agente

Fuente de datos

* Automatic Attack Disruption es una capacidad específica de Microsoft Defender para aplicar acciones de bloqueo automáticas (requiere habilitación y requisitos del producto).

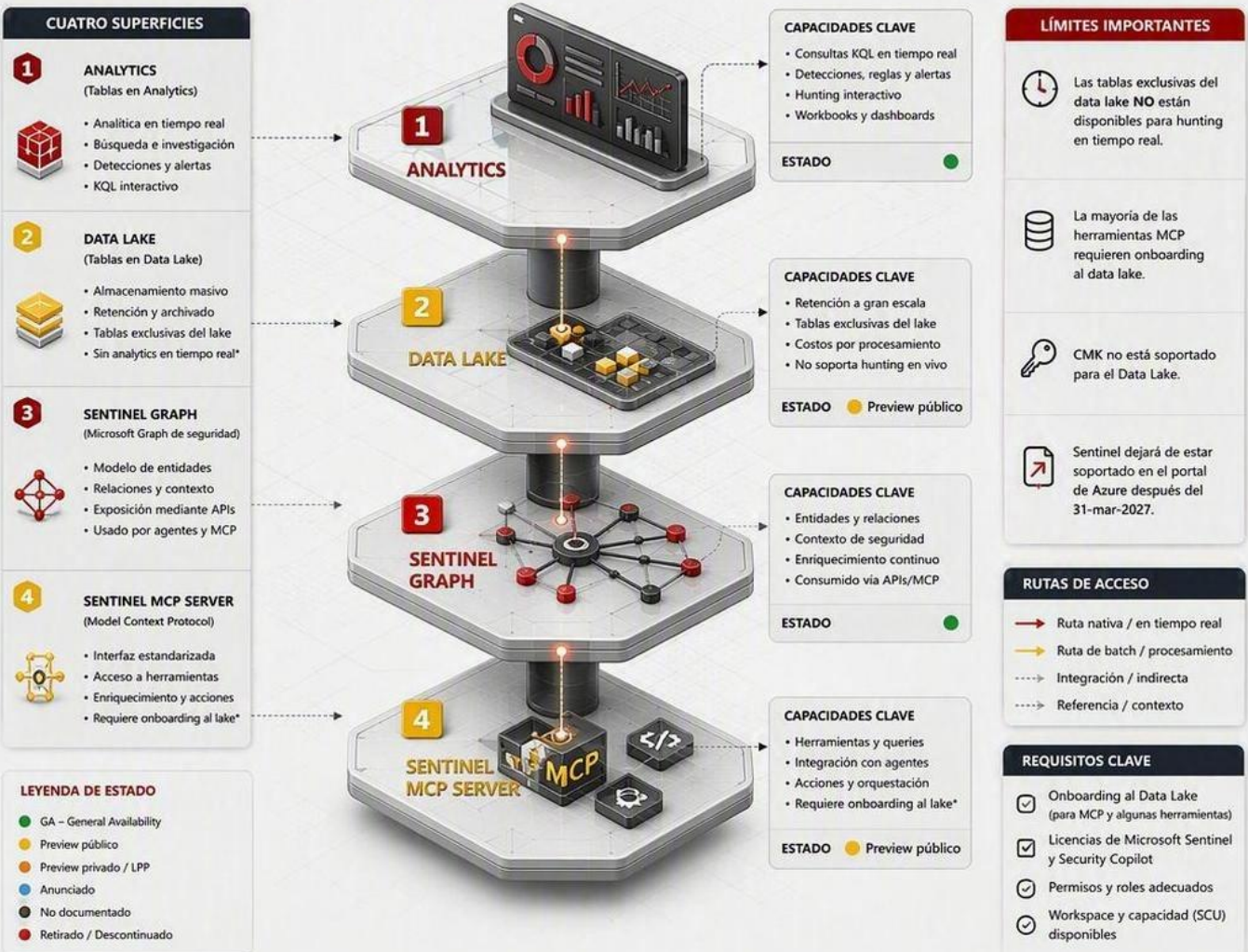
Cuatro superficies de datos y razonamiento en Microsoft Sentinel

SERIE: MICROSOFT SECURITY COPILOT
ARQUITECTURA, INTEGRACIÓN,
OPERACIÓN Y GOBIERNO



9 / 12

Microsoft Sentinel expone cuatro superficies complementarias para consulta, analítica y acción. Cada una tiene capacidades, límites y rutas de acceso específicas.
El uso correcto de cada superficie maximiza cobertura y rendimiento.



RUTAS DE ACCESO Y USO TÍPICO



COMPARATIVA DE SUPERFICIES

Superficie	Analítica en tiempo real	Tablas exclusivas	Retención escala	Hunting KQL interactivo	MCP / Agentes (requiere lake)	CMK soportado
1 Analytics	✓	Parcial**	Limitada	✓	Opcional	✓
2 Data Lake	X	✓	✓	X	✓	X Preview público
3 Graph	✓***	N/A	Contexto	N/A	✓	✓
4 MCP Server	N/A	Depende	Depende	Depende	✓	✓ Preview público

* Requiere onboarding al Data Lake ** Depende del flujo (tablas en Analytics) *** A través de APIs/MCP, no para KQL directo

CONSIDERACIONES

- El Data Lake es óptimo para retención y análisis a gran escala, no para hunting en vivo.
- Las rutas de acceso tienen costos y requisitos distintos.
- Valide permisos, workspace y capacidad antes de usar cada superficie.
- La residencia de datos y el cumplimiento aplican según la configuración del tenant y del workspace.

FUENTES (CLAVES)

Ver Anexo A del informe para la tabla completa de fuentes de Microsoft.

Claves: [A-xx] [B-xx] [C-xx] [D-xx] [E-xx]



El plano de control de Security Copilot

SERIE: MICROSOFT SECURITY COPILOT
ARQUITECTURA, INTEGRACIÓN,
OPERACIÓN Y GOBIERNO



10 / 12

El control efectivo se basa en identidad, datos, accesos, capacidad, terceros, auditoría y gobierno continuo.

El acceso sigue el principio de mínimo privilegio y contexto.



Análisis asistido no es evidencia forense

SERIE: MICROSOFT SECURITY COPILOT
ARQUITECTURA, INTEGRACIÓN,
OPERACIÓN Y GOBIERNO



11 / 12

Security Copilot amplifica el análisis e investigación, pero no reemplaza los procesos forenses ni garantiza la cadena de custodia. La evidencia proviene de fuentes y herramientas especializadas; la IA entrega análisis derivados que requieren validación humana.

LO QUE APORTA SECURITY COPILOT (Análisis asistido)

- Análisis de scripts**
Explica comportamiento y hallazgos.
- Análisis de archivos**
Describe indicadores y características.
- Resumen de dispositivos**
Sintetiza configuraciones, eventos y hallazgos.
- Cronologías**
Construye líneas de tiempo de actividades.
- Consultas KQL**
Ayuda a crear y explicar consultas.
- Investigación de entidades**
Relaciona usuarios, hosts, IPs, dominios, etc.
- Reportes e informes**
Genera informes ejecutivos y técnicos.

Valor: velocidad, contexto, correlación y recomendaciones.
Resultado: análisis derivado, no evidencia primaria.



LO QUE PERMANECE FUERA DEL ALCANCE (Evidencia forense)

- Adquisición**
Obtención controlada de datos desde la fuente.
- Hashing e integridad**
Cálculo y verificación de hashes criptográficos.
- Sellado y etiquetado**
Identificación única, fecha/hora y firma.
- Cadena de custodia**
Registro continuo de posesión y transferencias.
- Admisibilidad**
Cumplimiento legal y de estándares probatorios.
- Preservación externa**
Almacenamiento seguro y controles físicos.
- Atestación del analista**
Validación y firma profesional del perito.

Sin estos controles, la evidencia puede ser cuestionada o inadmisible en un proceso legal.

CADENA DE CUSTODIA: PROCESO FORENSE RECOMENDADO



HERRAMIENTAS Y FUENTES DE EVIDENCIA

- Live Response**
Adquisición remota controlada.
- Investigation Package**
Recolección de artefactos del dispositivo.
- APIs y conectores**
Extracción de datos estructurados.
- Microsoft Sentinel Data Lake**
Retención y consulta de datos a gran escala. (No es herramienta forense de adquisición)
- Otras herramientas forenses**
EnCase, FTK, X-Ways, Autopsy, etc.

RELACIÓN SECURITY COPILOT EN EL PROCESO



CONSIDERAR SIEMPRE

- La salida de IA es un análisis derivado.
- La evidencia subyacente debe preservarse de forma independiente.
- Documentar fuentes, herramientas y pasos realizados.
- Mantener trazabilidad entre evidencia y análisis generado.
- Seguir marcos y políticas de la organización y requisitos legales.

LIMITACIONES CLAVE

- No existe garantía documentada de integridad probatoria en las salidas de Security Copilot.
- Los prompts y salidas pueden contener información sensible: aplicar políticas de datos y residencia.
- El Data Lake de Sentinel aporta retención, no cadena de custodia.
- Las acciones de Live Response o API no quedan automáticamente reflejadas en los reportes.

BUENAS PRÁCTICAS

- Separar roles: analista / perito / aprobador.
- Usar herramientas forenses para adquisición y preservación.
- Registrar hashes, hora, fuente y responsable en cada paso.
- Conservar evidencias originales inalteradas.
- Usar Security Copilot como acelerador de análisis, no como fuente de evidencia.
- Revisar y firmar manualmente todos los informes.

DECISIÓN PARA CISO

- Definir política de uso de IA en investigación.
- Aprobar herramientas forenses y repositorios.
- Establecer requisitos de auditoría y retención.
- Capacitar equipos en cadena de custodia.
- Evaluar riesgos legales y regulatorios.



LEYENDA DE ESTADO

- GA - General Availability
- Preview público
- Preview privado / LPP
- Anunciado
- No documentado
- Retirado / Descontinuado

NOTAS CLAVE

- El análisis asistido no reemplaza el criterio del analista ni el proceso legal.
- Todo entregable debe basarse en evidencia válida y verificable.
- La organización es responsable de la cadena de custodia.

FUENTES (CLAVES)

Ver Anexo A del informe para la tabla completa de fuentes de Microsoft.

Claves: [A-xx] [B-xx] [C-xx] [D-xx] [E-xx]



Doce decisiones para una adopción controlada

SERIE: MICROSOFT SECURITY COPILOT
ARQUITECTURA, INTEGRACIÓN,
OPERACIÓN Y GOBIERNO



12 / 12

Un marco práctico para adoptar Security Copilot con seguridad, control y valor.
Priorice las decisiones en este orden y documente supuestos, límites y dependencias.
Gobernar antes de automatizar. Medir antes de escalar.

ONDA 1

FUNDAMENTOS

Establecer la base técnica y operativa.



1



Confirmar alcance y elegibilidad

- Verifique licencias y productos elegibles.
- Defina casos de uso prioritarios (GA).
- Identifique dependencias y restricciones.

2



Definir geografía y workspaces

- Elija la ubicación del workspace (immutable).
- Defina estrategia de residencia y evaluación de prompts.
- Cree workspaces por propósito y límites.

3



Establecer capacity y overage (SCU)

- Defina capacity inicial por workspace.
- Configure overage (0-999 SCU o ilimitado).
- Documente alertas y umbrales.

4



Diseñar identidad y Conditional Access

- Asigne roles de Security Copilot (Owner/Contributor).
- Use groups role-assignable.
- Aplique RBAC de productos de origen y Conditional Access.

PRINCIPIOS TRANSVERSALES



Mínimo privilegio y necesidad de conocer.



Acceso y ejecución on-behalf-of del usuario.



Contexto y gobernanza antes de automatizar.



Transparencia, auditoría y evidencia.



Controles en plataforma y productos de origen.



Medir antes de escalar.

ONDA 2

GOBIERNO

Configurar controles y políticas clave.



5



Decidir data sharing y feedback

- Evalúe impacto de data sharing fuera de geografía.
- Defina envío de feedback y mejora de productos.
- Documente consentimiento y excepciones.

6



Habilitar auditoría y DSPM for AI

- Active Unified Audit Log (UAL) y retenciones.
- Habilite DSPM for AI (contenido de prompts y respuestas).
- Defina retención mínima (180 días recomendado).

7



Regular sesiones compartidas

- Defina política para backends no reevaluados.
- Restrinja o deshabilite plugin en el backend cuando aplique.
- Informe al usuario del riesgo.

8



Gobernar plugins, MCP y terceros

- Apruebe e inventarie plugins, conectores, promptbooks y MCP.
- Implemente AllowedTools y autenticación.
- Revise seguridad del endpoint y dependencia de terceros.

ONDA 3

OPERACIÓN

Integrar, operar y preparar el SOC.



9



Seleccionar casos de uso (GA primero)

- Priorice funcionalidades en GA.
- Valide valor, riesgos y requisitos.
- Establezca plan de adopción incremental.

10



Integrar SOC, Logic Apps y promptbooks

- Diseñe playbooks asistidos.
- Use Logic Apps y promptbooks para tareas repetitivas.
- Automatice con aprobación y registro.

11



Definir procedimiento forense y de evidencia

- Separe análisis de IA de evidencia probatoria.
- Documente cadena de custodia y retención.
- Use Unified Audit Log y Purview.

12



Preparar migración y dependencias Sentinel

- Revise plan de migración del portal de Azure.
- Valide uso de Analytics, Data Lake, Graph y MCP.
- Planifique CMK y costos de procesamiento.

MÉTRICAS DE ÉXITO



Casos de uso en producción (GA) con valor medido.



Consumo SCU dentro de capacidad planificada.



Cobertura de auditoría y retención cumplida.



Adopción segura por analistas y equipos.



Reducción de MTTR y mejora de calidad.

ONDA 4

ESCALADO

Expandir con control, medición y mejora.



Evaluar agentes

- Compare Microsoft, partners, propios y Foundry.
- Considere identidad, herramientas y estado.



Medir y optimizar SCU

- Analice consumo por cargas y workspace.
- Optimice prompts, agentes y consultas.



Controlar Preview y cambios

- Monitoree capacidades Preview y anuncios.
- Mantenga planes de contingencia.



Revisar retro y dependencias

- Vigile retro, fechas clave y cambios.
- Actualice arquitectura y procedimientos.



Actualizar trazabilidad

- Mantenga inventario de decisiones.
- Versione evidencias y supuestos.



Fortalecer capacitación y cultura

- Capacite analistas y desarrolladores.
- Fomente uso seguro y responsable.

NOTAS CLAVE

- GA y Preview público consumen SCU.
- Preview privado no consume SCU.
- Las SCU no se comparten entre workspaces.
- El overage puede generar costos adicionales.
- La capacidad se renueva por hora de reloj.



Conditional Access se aplica en cada invocación.



Las sesiones compartidas no reevalúan plugins en algunos backends.



Data sharing puede permitir almacenamiento fuera de la geografía del workspace.



Security Copilot no es servicio EU Data Boundary.



Unified Audit Log requiere habilitación explícita.



DSPM for AI captura contenido de prompts y respuestas (opt-in).



Las rutas de acceso a datos tienen costos y requisitos distintos.

ESTADO DE CICLO DE VIDA

- GA - General Availability
- Preview público
- Preview privado / LPP
- Anunciado
- No documentado
- Retirado / Descontinuado

FUENTES (CLAVES)

Ver Anexo A del informe para la tabla completa de fuentes de Microsoft.

Claves: [A-xx] [B-xx] [C-xx] [D-xx] [E-xx]

